ENTERPRISE SOAR REFERENCE ARCHITECTURE

A numbered architecture catalog of modules, submodules, and capabilities

Scope: A broad reference blueprint for designing a large, enterprise-grade Security Orchestration, Automation, and Response platform. It includes core SOAR functions plus adjacent SOC, AI, governance, and infrastructure capabilities.

Important limitation: No public, authoritative list proves that these are literally every component of the world's largest SOAR platform or of any single vendor. Commercial platforms differ in product boundaries, editions, integrations, and optional modules. This document is a comprehensive reference architecture—not a claim that every vendor implements every item.

How to read it: The 30 numbered modules are functional domains. Individual bullets describe capabilities that may be built in, integrated, optional, or supplied by adjacent products.

Prepared with reference to public vendor documentation from Splunk SOAR and Cortex XSOAR.

Contents

1. Data Ingestion and Collection
2. Integration and Connector Management
3. Alert Management and Triage
4. Event Correlation Engine
5. Incident and Case Management
6. Playbook Engine
7. Workflow Orchestration
8. Automation Execution Engine
9. Investigation and Evidence Management
10. Threat Intelligence Management
11. Threat Hunting
12. Detection Engineering
13. AI and Machine Learning Engine
14. LLM Engine and AI Agents
15. Response and Containment Engine
16. Human Approval and Analyst-in-the-Loop
17. Asset Management and Inventory
18. Identity and Access Context
19. Vulnerability and Exposure Context
20. Cloud and Container Security
21. Risk Management and Business Impact
22. Dashboards, Analytics and Reporting
23. Security, Governance and Compliance
24. Platform Infrastructure and Reliability
25. Administration, APIs and Extensibility
26. Knowledge Base and SOC Runbooks
27. Notification and Escalation Engine
28. Testing, Simulation and Validation
29. Continuous Improvement and Feedback
30. Advanced Enterprise and MSSP Capabilities

1. Data Ingestion and Collection

- Log collection: Syslog, Windows Event Logs, Linux logs, application logs, web server logs, database audit logs, DNS/DHCP logs, authentication logs, and network-device logs.
- Event sources: SIEM, EDR/XDR, IDS/IPS, firewalls, cloud audit services, identity providers, email-security tools, vulnerability scanners, and business applications.
- Ingestion methods: REST API polling, webhooks, Syslog over UDP/TCP/TLS, agents, file uploads, scheduled jobs, message queues, and event streams.
- Processing: parsing, field extraction, normalization, timestamp conversion, schema validation, filtering, deduplication, and source tagging.
- Reliability and governance: buffering, retries, checkpoints, dead-letter queues, backpressure, collection-health monitoring, retention, PII masking, and data-quality metrics.

2. Integration and Connector Management

- Connector categories: SIEM, EDR/XDR, firewalls, IDS/IPS, NDR, DNS security, IAM/SSO/MFA, PAM, email security, ticketing, ITSM, cloud, containers, threat-intelligence feeds, and forensic tools.
- Connector lifecycle: installation, configuration, authentication, permission validation, connection tests, health checks, version compatibility, upgrades, and decommissioning.
- Action interface: action registry, input/output schemas, pagination, normalized results, API throttling, timeouts, retries, idempotency, and error classification.
- Credential management: secret references, scoped credentials, rotation, expiry monitoring, and audit of connector access.
- Extensibility: custom connectors, SDKs, connector tests, documentation, versioning, and compatibility checks.

3. Alert Management and Triage

- Lifecycle: received, normalized, enriched, triaged, assigned, investigating, escalated, resolved, closed, and reopened.
- Deduplication and grouping: identical alerts, recurring alerts, time-window grouping, and grouping by IP, user, host, attack type, or source.
- Triage: classify alert type, assess true/false-positive likelihood, identify missing context, set priority, and route to analysts.
- Scoring: severity, confidence, asset criticality, threat reputation, exploitability, business impact, recurrence, and user risk.
- Operations: analyst assignment, workload balancing, queue management, SLA tracking, aging alerts, alert-quality metrics, and triage history.

4. Event Correlation Engine

- Correlation methods: rule-based, threshold-based, sequence-based, time-window, frequency-based, statistical, behavioral, and graph-based correlation.
- Entity relationships: connect IP addresses, users, hosts, processes, domains, URLs, email messages, files, cloud resources, and sessions when supported by evidence.
- Attack sequences: correlate failed and successful logins, phishing and execution, suspicious processes and network connections, privilege escalation, lateral movement, and exfiltration indicators.
- Time handling: timestamp normalization, event ordering, late-arriving events, sliding windows, session reconstruction, and timelines.
- Rule operations: authoring, validation, testing, tuning, versioning, performance monitoring, and explainable correlation results.

5. Incident and Case Management

- Case creation: manual or automatic creation, grouping related alerts, unique IDs, incident type, severity, priority, and ownership.
- Case record: description, affected assets and identities, related alerts, indicators, evidence, timeline, business impact, and investigation notes.
- Workflow: assignment, team queues, transfer, escalation, SLA tracking, approvals, and handover between shifts.
- Collaboration: comments, internal notes, task assignment, evidence sharing, activity feeds, and collaboration history.
- States and closure: open, in progress, pending approval, contained, resolved, closed, and reopened; root cause, actions, recovery status, lessons learned, and closure approval.
- Metrics: MTTA, MTTD, MTTR, SLA compliance, case volume, reopened-case rate, and workload per analyst.

6. Playbook Engine

- Authoring: visual or code-based editor, reusable actions, templates, documentation, import/export, and reusable sub-playbooks.
- Triggers: new alert, case creation, webhook, schedule, threshold, manual launch, or external event.
- Logic: conditions, branching, loops, parallel and sequential steps, nested workflows, variables, transformations, and dynamic paths.
- Execution control: start, pause, resume, cancel, checkpoints, retries, timeouts, error branches, state persistence, and recovery policies.
- Lifecycle: draft, test, review, approve, publish, version, roll back, and retire.
- Testing and safety: dry-run, mock connectors, test data, step inspection, regression tests, permission checks, loop limits, emergency stop, and duplicate-run protection.

7. Workflow Orchestration

- Task scheduling: immediate, scheduled, recurring, and event-driven execution.
- Dependency management: prerequisites, sequential steps, parallel branches, and completion conditions.
- Distributed execution: workers, queues, prioritization, concurrency limits, fairness, and resource allocation.
- Reliability: retry policies, dead-letter handling, checkpoints, resumption, deadlines, cancellation, and failure recovery.
- Consistency: idempotency keys, execution-state persistence, duplicate-event protection, and compensating workflows.
- Observability: execution traces, queue depth, latency, failure rates, worker health, and capacity monitoring.

8. Automation Execution Engine

- Action registry and executor for approved security and IT actions.
- Script execution for supported languages such as Python, PowerShell, and Bash, subject to sandboxing and policy.
- Input validation, parameter schemas, output normalization, structured errors, and result storage.
- Workers and execution limits: CPU, memory, duration, concurrency, and payload size.
- Security: least privilege, scoped service accounts, secret access control, sandboxing, allowlists, and approval gates.
- Dry-run, cancellation, audit logging, and post-action verification against the target system.

9. Investigation and Evidence Management

- Evidence collection: logs, process details, network connections, authentication events, files, email headers, and cloud events.

- Investigation areas: host, network, identity, email, file, cloud, and application investigations.
- Timeline reconstruction and correlation of evidence across sources.
- Integrity: hashes, source attribution, timestamps, chain of custody, access controls, and tamper-evident records where required.
- Investigation templates, forensic-tool integrations, findings, hypotheses, conclusions, retention, and controlled evidence export.

10. Threat Intelligence Management

- Sources: commercial and community feeds, APIs, internal intelligence, reports, and trusted partner sources.
- Indicators: IP addresses, domains, URLs, file hashes, email addresses, and other supported IOCs.
- Normalization, validation, deduplication, reputation lookup, context enrichment, confidence, freshness, and expiry.
- Standards and mapping: STIX/TAXII where supported, and mapping to MITRE ATT&CK techniques when evidence supports it.
- Feed health, lifecycle states, source reliability, intelligence scoring, access control, sharing rules, hunting integration, and response integration.

11. Threat Hunting

- Hunt campaigns, scopes, hypotheses, owners, schedules, and documentation.
- Query building for SIEM, EDR, network, identity, and cloud sources.
- IOC-based, behavioral, cross-source, and ATT&CK-informed hunting.
- Result triage, false-positive handling, evidence linking, and conversion of confirmed findings into incidents.
- Hunt-to-detection and hunt-to-playbook workflows, coverage-gap analysis, and effectiveness metrics.

12. Detection Engineering

- Rule repository, ownership, source references, versioning, and supported rule formats such as Sigma or vendor-native formats.
- Rule authoring, syntax and schema validation, test datasets, simulation, regression tests, and controlled deployment.
- Threshold tuning, false-positive reduction, query-performance monitoring, and rollback.
- Mapping to ATT&CK techniques, coverage-gap analysis, detection testing, and rule health monitoring.
- Metrics: precision, recall where measurable, false-positive rate, coverage, latency, and operational cost.

13. AI and Machine Learning Engine

- Data preparation: feature extraction, normalization, missing-value handling, label validation, class-imbalance handling, and leakage prevention.
- Model approaches: supervised classification, anomaly detection, clustering, behavioral analytics, time-series analysis, and risk scoring.
- Model lifecycle: training, validation, benchmarking, registry, versioning, deployment, rollback, and retraining.
- Inference: real-time and batch prediction APIs, confidence scores, timeouts, throughput limits, and fallback behavior.
- Evaluation: precision, recall, F1, false-positive and false-negative rates, ROC-AUC where appropriate, latency, and throughput.
- Monitoring and governance: data/concept drift, explainability, model integrity, access control, analyst feedback, and safe fallback.

14. LLM Engine and AI Agents

- LLM gateway: local and hosted models, routing, provider fallback, timeouts, retries, token/cost tracking, and rate limits.

- Context builder: alert details, relevant logs, asset and identity context, threat-intelligence results, minimization, and sensitive-data redaction.
- Prompt management: templates, versioning, examples, test suites, regression tests, and controlled changes.
- Structured outputs: attack type, severity recommendation, evidence-based explanation, recommended actions, uncertainty, JSON schema validation, and source references.
- Agent capabilities: planning, task decomposition, bounded tool calling, observations, read-only investigation, escalation, and explicit completion criteria.
- RAG and knowledge retrieval: SOC runbooks, incident history, policies, document indexing, retrieval ranking, and citations to internal sources.
- AI security: prompt-injection defenses, untrusted-log handling, tool permissions, output validation, exfiltration controls, tool-call limits, human approval, and audit.
- Evaluation: hallucination, grounding, classification, recommendation quality, prompt-injection resilience, latency, and cost.

15. Response and Containment Engine

- Network actions: block/unblock IPs, domains or URLs; update firewall rules; apply DNS or network-access restrictions.
- Endpoint actions: isolate host, quarantine file, initiate scan, collect artifacts, and terminate confirmed malicious processes where authorized.
- Identity actions: suspend account, revoke sessions/tokens, force password reset, require additional authentication, and remove unauthorized privileges.
- Email actions: quarantine messages, search for related messages, remove malicious mail where authorized, and block senders/domains.
- Cloud actions: revoke exposed credentials, restrict workloads, apply approved policies, and isolate affected resources.
- Policy controls: allowlists, target scope, severity-based rules, approval requirements, rate limits, emergency stop, and expiry for temporary blocks.
- Verification and recovery: confirm target-system state, detect partial failure, rollback supported changes, restore service, and record outcomes.

16. Human Approval and Analyst-in-the-Loop

- Approval policies based on action type, severity, asset criticality, and business impact.
- Approval requests containing rationale, evidence, target, proposed action, expected impact, and rollback plan.
- Approver routing, multiple approvers, expiry, rejection handling, escalation, and acknowledgement.
- Separation of duties, emergency authorization, analyst override, and the ability to pause or cancel workflows.
- Feedback collection and immutable or tamper-evident records of decisions, approvers, timestamps, and outcomes.

17. Asset Management and Inventory

- Discovery and inventory of endpoints, servers, network devices, cloud resources, applications, containers, and services.
- Entity resolution to merge duplicate records from multiple tools.
- Ownership, classification, criticality, business-service relationships, exposure, and health.
- Asset history, lifecycle, unmanaged-asset detection, inventory reconciliation, and last-seen timestamps.
- Mapping assets to alerts, incidents, vulnerabilities, identities, and response actions.

18. Identity and Access Context

- Inventory of users, service accounts, privileged accounts, roles, groups, and authentication providers.
- Authentication and session context, failed/successful logins, privilege changes, and available behavioral indicators.
- Identity-to-device, IP, session, and incident correlation.
- Privileged-account monitoring, access reviews, least-privilege checks, and service-account governance.
- Response workflows for account suspension, session revocation, and privilege remediation, subject to authorization.
- Privacy controls and auditing of access to sensitive identity information.

19. Vulnerability and Exposure Context

- Ingest findings from vulnerability scanners and asset-management tools.
- Track CVEs, affected versions, CVSS scores, exploit intelligence, exposure, and available patch status.
- Map vulnerabilities to assets, owners, business services, and relevant incidents.
- Prioritize remediation using severity, exploitability, exposure, asset criticality, and evidence.
- Remediation tracking, patch verification, exceptions, risk acceptance, expiry dates, and reporting.

20. Cloud and Container Security

- Inventory cloud accounts, subscriptions, projects, workloads, identities, and audit sources.
- Cloud configuration and identity monitoring; cloud workload and container context.
- Kubernetes cluster, node, workload, and container-image findings where supported.
- Cloud threat detection, secret exposure handling, policy enforcement, and multi-cloud correlation.
- Cloud incident response, evidence preservation, approved containment, access governance, and cost monitoring.

21. Risk Management and Business Impact

- Risk register, risk owners, assessment methodology, and review dates.
- Risk scoring based on likelihood, severity, exposure, business criticality, and evidence.
- Business-service mapping and impact analysis for confidentiality, integrity, and availability.
- Risk acceptance, exceptions, mitigation actions, residual risk, and due dates.
- Risk trends, incident mapping, executive reporting, and governance of scoring models.

22. Dashboards, Analytics and Reporting

- SOC overview: alert and incident volume, severity, open cases, integration health, and playbook status.
- Analyst dashboards: assigned alerts, cases, tasks, pending approvals, SLA violations, and workload.
- Automation dashboards: executions, success/failure, latency, retries, stuck jobs, and approval rates.
- Threat dashboards: attack types, targeted assets, IOCs, and ATT&CK coverage where measured.
- Metrics: MTTD, MTTA, MTTR, false-positive rate, automation success, SLA compliance, and coverage.
- Reports: incident, investigation, response, vulnerability, risk, audit, and team-performance reports; scheduled exports and access-controlled sharing.
- Visualizations: timelines, correlation graphs, risk matrices, trends, and workflow execution graphs.

23. Security, Governance and Compliance

- Authentication: SSO, MFA, SAML/OIDC, session management, and secure logout where supported.
- Authorization: RBAC, fine-grained permissions, tenant/team/case access, action-level permissions, and separation of duties.
- Secrets management: encrypted credentials, API keys, token rotation, expiry, vault integration, and access audit.
- Audit: logins, configuration changes, playbook edits, approvals, response actions, exports, and administrative operations.
- Application security: input validation, secure sessions, API authorization, dependency scanning, vulnerability management, and secure updates.
- Data protection: encryption in transit/at rest, classification, masking, retention, deletion, and backup protection.
- Governance: policy baselines, change control, access reviews, exception records, compliance evidence, and AI oversight.

24. Platform Infrastructure and Reliability

- Architecture: frontend, backend APIs, modular services, background workers, integration services, and AI inference services.
- Storage: relational database, event/search storage, cache, evidence object storage, model artifacts, and audit records.
- Messaging: brokers, task queues, event streaming, dead-letter queues, persistence, and retry handling.
- Deployment: containers, Docker Compose for smaller deployments, Kubernetes where appropriate, CI/CD, configuration management, and infrastructure as code.
- Reliability: health checks, redundancy, failover, load balancing, graceful degradation, backup, restore tests, RPO, and RTO.
- Observability: application logs, metrics, traces, error tracking, queue depth, resource use, and service health.
- Scale and operations: horizontal scaling, database optimization, pagination, rate limiting, load testing, capacity planning, upgrades, rollback, and diagnostics.

25. Administration, APIs and Extensibility

- Administration: users, roles, teams, organizations, tenant settings, quotas, feature entitlements, and configuration history.
- APIs: REST endpoints, authentication, scopes, pagination, filtering, versioning, rate limits, error schemas, and documentation.
- Webhooks and events: subscriptions, signature validation, delivery tracking, retries, filtering, and replay protection.
- Developer tools: connector SDK, action framework, playbook development tools, local tests, examples, and documentation.
- Plugin ecosystem: custom connectors, actions, parsers, dashboards, enrichment providers, permissions, and version compatibility.
- Localization, accessibility, time zones, licensing/usage tracking, support bundles, diagnostics, and configuration rollback.

26. Knowledge Base and SOC Runbooks

- Runbooks for investigation, containment, recovery, and recurring SOC procedures.
- Knowledge articles, previous incident lessons, search, semantic retrieval, ownership, review dates, and version history.
- Approval and publication workflow; document quality checks and expiration of stale content.
- AI knowledge integration with source attribution, access controls, and context-aware retrieval.
- Runbook testing, usage analytics, and links between procedures, cases, and playbooks.

27. Notification and Escalation Engine

- Channels: email, chat/ collaboration tools, webhooks, ticketing systems, and supported paging tools.

- Templates, routing rules, severity-based recipients, on-call schedules, and analyst preferences.
- SLA reminders, escalation timers, acknowledgement, retries, delivery tracking, and escalation history.
- Deduplication, quiet-hour policies where appropriate, and secure notification content that avoids leaking sensitive evidence.

28. Testing, Simulation and Validation

- Unit, integration, end-to-end, acceptance, regression, and security testing.
- Connector tests for authentication, permissions, API behavior, timeouts, and error cases.
- Playbook tests for branches, retries, approvals, timeouts, rollback, and failure paths.
- Synthetic events, authorized attack simulation, detection validation, and response tests in a controlled environment.
- Load/stress testing, AI evaluation, prompt-injection testing, failure injection, test coverage, and test reports.

29. Continuous Improvement and Feedback

- Analyst feedback on alerts, classifications, explanations, and recommended actions.
- False-positive root causes, detection tuning, playbook optimization, and automation-gap analysis.
- Model improvement using reviewed and properly governed evaluation data.
- Post-incident reviews, recurring-cause analysis, KPI review, and controlled change recommendations.
- Continuous validation of rules, connectors, playbooks, policies, and AI components.

30. Advanced Enterprise and MSSP Capabilities

- Multi-tenant operations with strict tenant data and permission isolation.
- Federated search and cross-environment workflows under explicit authorization.
- Advanced graph analytics and attack-path context across identities, assets, vulnerabilities, and incidents.
- Integration with security data lakes, digital forensics, malware analysis, and threat-emulation platforms.
- Business continuity workflows, advanced policy evaluation, cross-platform response, and enterprise-wide incident coordination.
- AI-agent governance: bounded tools, quotas, audit, permissions, cost limits, and human oversight.

Reference Sources and Scope Notes

- **Splunk SOAR documentation — overview and platform capabilities**
  https://help.splunk.com/en/splunk-soar
- **Splunk SOAR Cloud introduction — ingestion, triage, case tracking, and playbook automation**
  https://help.splunk.com/en/splunk-soar/soar-cloud/soar-cloud-service-description/the-splunk-soar-service/splunk-soar-cloud-introduction
- **Splunk SOAR features — integrations, automated actions, playbooks, dashboards, and case management**
  https://www.splunk.com/en_us/products/splunk-security-orchestration-and-automation-features.html
- **Cortex XSOAR Administrator Guide — incidents, integrations, indicators, and playbooks**
  https://docs-cortex.paloaltonetworks.com/r/Cortex-XSOAR/8/Cortex-XSOAR-Administrator-Guide/Concepts

Interpretation: The core SOAR center of gravity is integration/orchestration, playbook automation, and incident/case management. Threat intelligence, investigation, AI/ML, vulnerability context, cloud security, and enterprise infrastructure may be integrated capabilities or separate products depending on the architecture.